Strong authentication and privileged access — KRL-ADM

Banque Kerlann (fictitious) · KRL-ADM — IAM administration console

Prepared by: **Attest (AI-assisted)**
Auditor sign-off: **pending**
Owner: **IT department — IAM team**
Date: **2026-11-04 06:30**
Run: **iam**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

OPINION AFTER REMEDIATION

Unsatisfactory

Basis for opinion

7 controls tested (7 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-04 06:30, environment: Demonstration pre-production. The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

7 controls tested	**6** findings	**0** findings closed and verified · 5 re-tested compliant, closure pending approval	**1** open findings
0 human approvals · 5 pre-approved (demo)	**8** sensitive data items masked in evidence	**1 min 27 s** audit duration	**$0.127 *** measured AI cost



Critical: 1 High: 2 Medium: 3 Low: 0

Key messages

- 6 findings across 7 controls: 1 critical, 2 high, 3 medium.
- 5 finding(s) re-tested compliant after a pre-approved change (not valid as an approval): closure pending owner approval, still counted in the opinion.
- 1 finding remains open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-IAM-01
Entity	Banque Kerlann (fictitious)
System	KRL-ADM — IAM administration console
System criticality	Supports critical or important functions (DORA)
Environment	Demonstration pre-production
Owner	IT department — IAM team

Lead auditor	Attest CI
Date	2026-11-04 06:30
Framework	DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4
Audited target	KRL-ADM IAM admin console (Banque Kerlann)
Work programme	existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Authentication and session settings of the KRL-ADM console
- Accounts with access to the console
- Logging of administrative actions

Out of scope

- Intrinsic strength of MFA factors (robustness of authentication means)
- Central directory and identity federation
- Physical controls

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fixes are drafted by the audit tool itself (self-review threat): closing a finding requires independent approval by the system owner.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2026-12-04
F-02	PSI-4.2	Mandatory MFA for users of critical system	High	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-02-02
F-03	PSI-4.7	No generic or shared admin accounts	High	Non-compliant		Action plan	2027-02-02
F-04	PSI-4.3	Strong password policy	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03

F-05	PSI-4.4	Account lockout after failed logins	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03
F-06	PSI-4.5	Inactive session timeout	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03
–	PSI-4.6	Logging of administration actions	High	Compliant			

4. Detailed findings and controls

F-01 PSI-4.1 Mandatory MFA for privileged accounts

Critical · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

MFA is enforced for all privileged admin accounts on KRL-ADM

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `false`
Expected: `true`

GET /api/security returned mfa_admin=False.

RISK

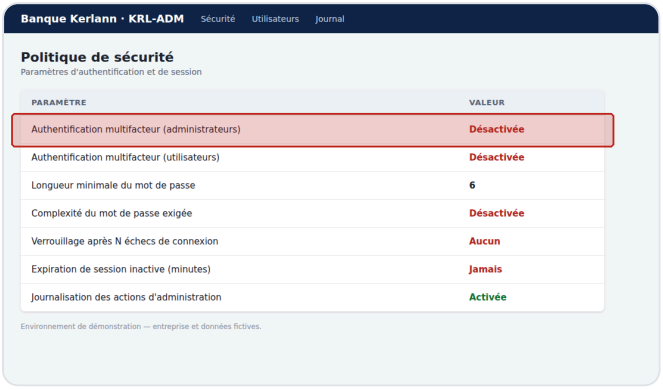
Without MFA for admins, stolen credentials allow full takeover of critical functions with no second barrier

RECOMMENDATION

Enable mandatory MFA for all privileged accounts by setting mfa_admin to true

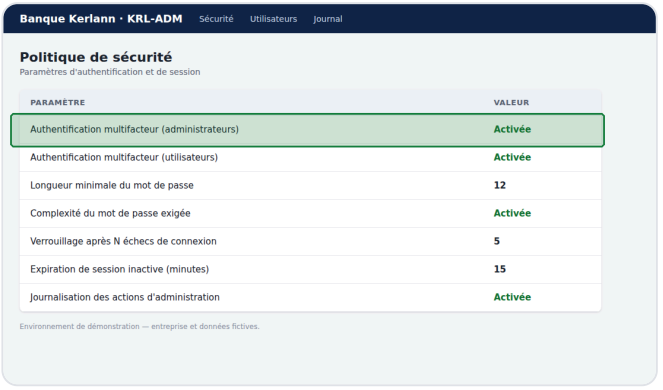
Due date: 2026-12-04 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_admin is true



At testing — The screenshot corroborates the test. The screenshot shows administrator MFA is disabled, matching the failed automated test.

2026-11-04 06:30:58 · SHA-256 2c179da7de6b0787…



After fix — The screenshot corroborates the test. The screenshot shows administrator MFA as Activée, matching the automated test pass for mfa_admin true.

2026-11-04 06:31:54 · SHA-256 1ac349360cec6caa…

> **Change request CHG-AUD-2026-IAM-01-01** · `PATCH /api/security {"mfa_admin": true}`
> Privileged admin accounts currently lack mandatory MFA, allowing full takeover with stolen credentials alone.
> Expected impact: Admins will be required to use MFA at login, requiring one-time enrollment for those not yet enrolled.
> Approved by: **IAM owner (CI)** · 2026-11-04 06:31:36 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T06:31:36Z · svc-change · mfa_admin: False → True

F-02 PSI-4.2 Mandatory MFA for users of critical system

High · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

MFA is enforced for standard users because KRL-ADM supports critical or important functions

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `false`

Expected: `true`

mfa_users is False.

RISK

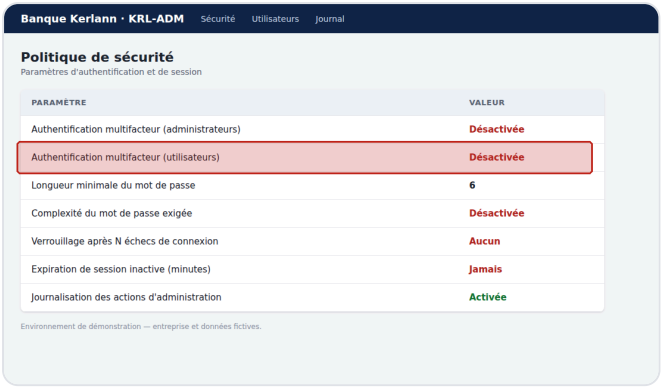
Without MFA for all users, compromised user credentials allow unauthorized access to critical functions

RECOMMENDATION

Enable mandatory MFA for standard users by setting mfa_users to true

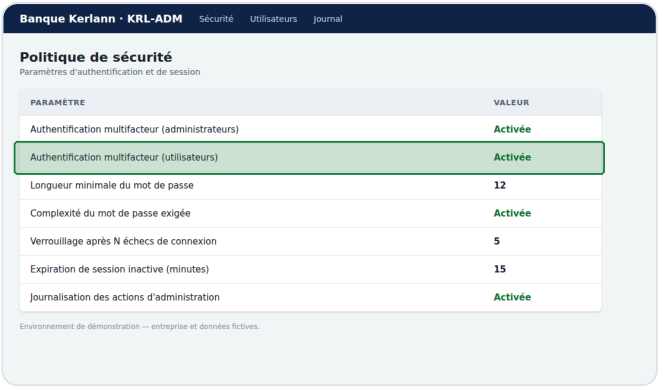
Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_users is true



At testing — The screenshot corroborates the test. The screenshot shows MFA for standard users as Désactivée, confirming mfa_users is false.

2026-11-04 06:30:58 · SHA-256 58ab95f59551dd5b…



After fix — The screenshot corroborates the test. The screenshot shows MFA for standard users as Activée, matching the automated pass result.

2026-11-04 06:31:52 · SHA-256 d9485860f37189c0…

> **Change request CHG-AUD-2026-IAM-01-02** · `PATCH /api/security {"mfa_users": true}`
> MFA must be enforced for standard users because KRL-ADM supports critical functions per PSI-4.2.
> Expected impact: Standard users will be required to use MFA at next authentication.
> Approved by: **IAM owner (CI)** · 2026-11-04 06:31:36 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T06:31:36Z · svc-change · mfa_users: False → True

F-03 PSI-4.7 No generic or shared admin accounts

High · Non-compliant · Action plan

CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)

CONDITION

Observed: `[{"login": "a.lefloch", "email": "a•••@kerlann-banque.example", "role": "admin"}, {"login": "ops", "email": "o•••@kerlann-banque.example", "role": "admin"}]`

Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`

1 of 2 admin account(s) violate nominative login or personal email requirements.

RISK

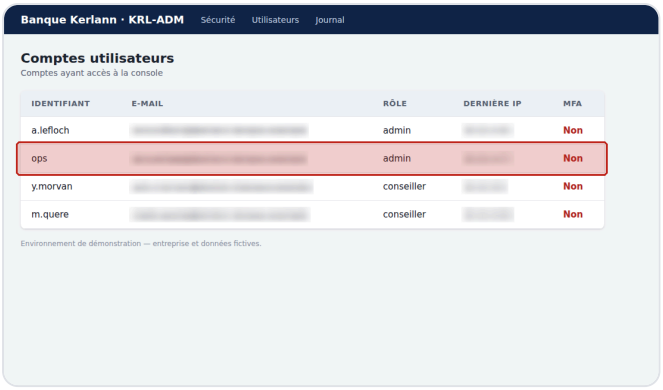
Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

RECOMMENDATION

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts

Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox



At testing — The screenshot corroborates the test. Screenshot shows two admin accounts including generic login ops alongside nominative a.lefloch. · 8/8 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 06:31:19 · SHA-256 189759b0a7634155…`

Manual remediation · CHG-AUD-2026-IAM-01-03
The admin account 'ops' uses a generic login and shared mailbox which destroys individual accountability for privileged actions.

1. Disable and then remove the generic/shared admin account 'ops' (ops-partage@kerlann-banque.example) so it can no longer authenticate or perform privileged actions.
2. Identify the legitimate individual(s) behind 'ops' and provision dedicated nominative admin accounts of the form initiale.nom with personal email addresses with least privilege.
3. Review /admin/journal and authentication logs for actions performed by 'ops' to re-attribute activity and rotate any shared credentials.
4. Re-run GET /api/users to verify all remaining role==admin accounts have nominative login and personal email with no function identifier or shared mailbox.

F-04 PSI-4.3 Strong password policy

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Passwords require a minimum length of 12 characters with complexity requirements enabled
PSI-4.3 · DORA 9(4)(d)

CONDITION

Observed: `{"password_min_length": 6, "password_require_complexity": false}`
Expected: `password_min_length >= 12 AND password_require_complexity == true`
password_min_length is 6 and password_require_complexity is False.

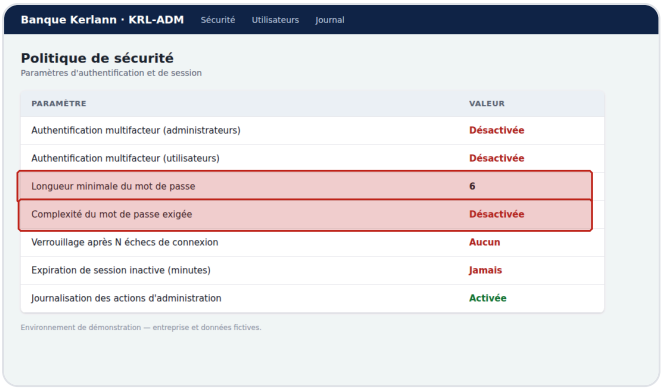
RISK

Weak or short passwords can be guessed or brute-forced, enabling unauthorized access to the system

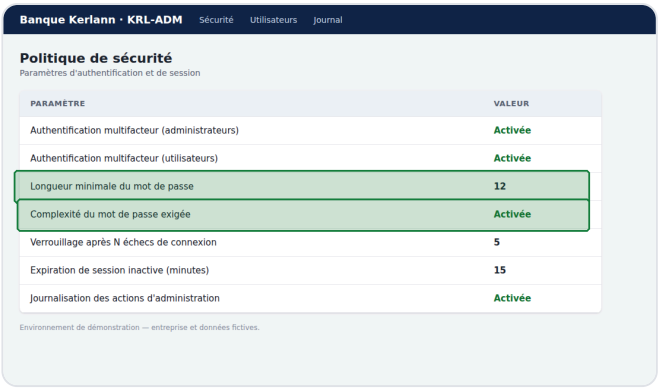
RECOMMENDATION

Enforce a minimum password length of 12 characters with complexity by correcting the password settings
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify password_min_length and password_require_complexity



At testing — The screenshot corroborates the test. The screenshot shows minimum password length 6 and complexity disabled, matching the automated failure.
`2026-11-04 06:30:58 · SHA-256 1c48df04737588f1…`



After fix — The screenshot corroborates the test. Screenshot shows minimum length 12 and complexity enabled, matching the automated pass.
`2026-11-04 06:31:53 · SHA-256 ec30dd44cdc2f97d…`

> **Change request CHG-AUD-2026-IAM-01-04** · `PATCH /api/security {"password_min_length": 12, "password_require_complexity": true}`
> Increase minimum password length to 12 and enable complexity to satisfy PSI-4.3.
> Expected impact: Users will need to set passwords of at least 12 characters meeting complexity requirements.
> Approved by: **IAM owner (CI)** · 2026-11-04 06:31:36 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T06:31:36Z · svc-change · password_min_length: 6 → 12; password_require_complexity: False → True

F-05 PSI-4.4 Account lockout after failed logins

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Accounts lock after at most 5 failed login attempts and lockout is never disabled

PSI-4.4 · DORA 9(4)(c)

CONDITION

Observed: `0`
Expected: `lockout_threshold >= 1 AND lockout_threshold <= 5`

lockout_threshold is 0, which is outside the required range 1 to 5 inclusive.

RISK

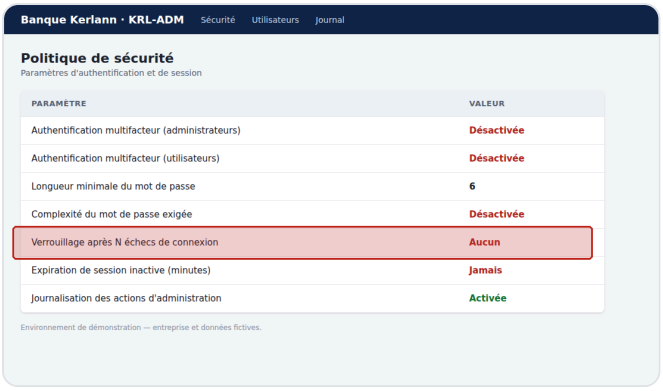
Without lockout, attackers can perform unlimited password-guessing attacks against accounts

RECOMMENDATION

Configure account lockout to 5 attempts at most by setting lockout_threshold between 1 and 5

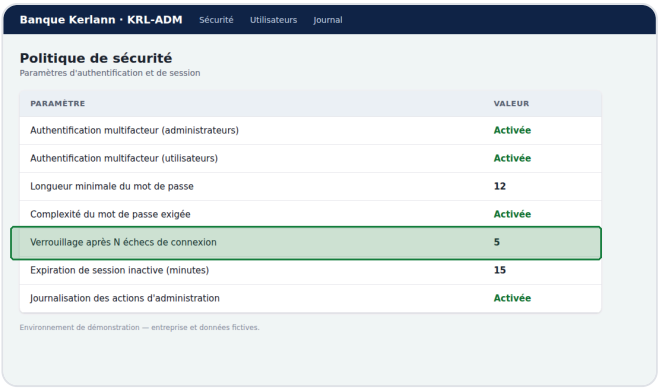
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that lockout_threshold is between 1 and 5 inclusive



At testing — The screenshot corroborates the test. The security policy shows lockout after failed logins is set to Aucun, confirming the observed threshold of 0.

`2026-11-04 06:30:59 · SHA-256 013a9eceeb05ebc4…`



After fix — The screenshot corroborates the test. The screenshot shows lockout after 5 failed attempts, matching the automated test value of 5.

`2026-11-04 06:31:51 · SHA-256 7d93abc7dc4c2b72…`

> **Change request CHG-AUD-2026-IAM-01-05** · `PATCH /api/security {"lockout_threshold": 5}`
> Lockout is currently disabled with value 0 and setting it to 5 restores compliance with the required 1 to 5 range.
> Expected impact: Users will be locked out after 5 consecutive failed login attempts.
> Approved by: **IAM owner (CI)** · 2026-11-04 06:31:36 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T06:31:36Z · svc-change · lockout_threshold: 0 → 5

F-06 PSI-4.5 Inactive session timeout

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Inactive sessions expire after at most 15 minutes and expiration is never disabled

PSI-4.5 · DORA 9(4)(c)

CONDITION

Observed: `0`

Expected: `session_timeout_minutes >= 1 AND session_timeout_minutes <= 15`

Observed session_timeout_minutes is 0, outside the required 1 to 15 inclusive.

RISK

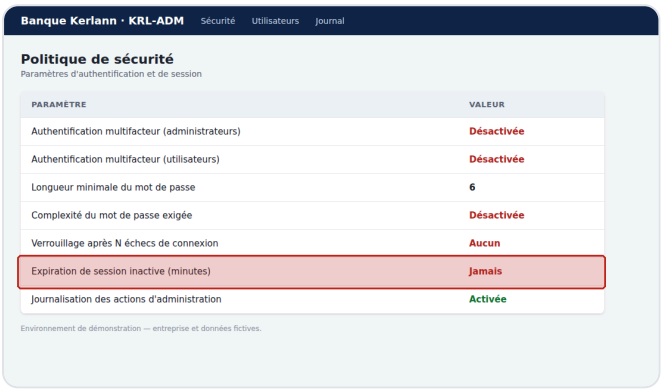
Unlimited inactive sessions allow session hijacking and unauthorized use of unattended workstations

RECOMMENDATION

Enforce inactive session expiration at 15 minutes at most by setting session_timeout_minutes between 1 and 15

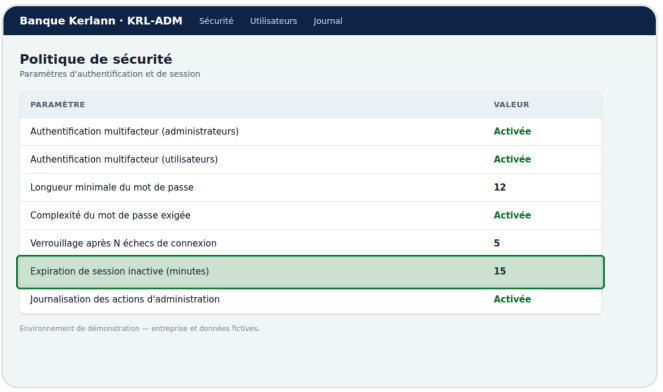
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that session_timeout_minutes is between 1 and 15 inclusive



At testing — The screenshot corroborates the test. The screenshot shows inactive session expiration set to Never, confirming the timeout is disabled.

`2026-11-04 06:31:14 · SHA-256 60a8b9c3793849fd…`



After fix — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 15 minutes, matching the automated observation of 15.

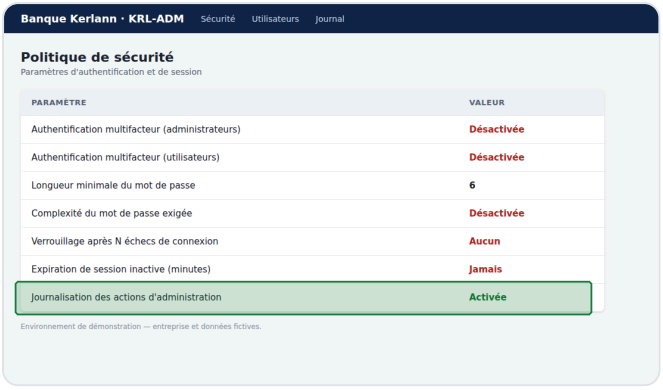
`2026-11-04 06:32:08 · SHA-256 3ba30f1088538a75…`

Change request CHG-AUD-2026-IAM-01-06 · `PATCH /api/security {"session_timeout_minutes": 15}`
Observed value 0 disables session expiration, so it must be set within the required 1 to 15 minute range.
Expected impact: Inactive users will be logged out after 15 minutes and will need to authenticate again.
Approved by: **IAM owner (CI)** · 2026-11-04 06:31:36 · pre-approved (demo, not valid as an approval) · applied and logged
System journal: 2026-11-04T06:31:36Z · svc-change · session_timeout_minutes: 0 → 15

PSI-4.6 Logging of administration actions

High Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`



At testing — The screenshot corroborates the test. The screenshot shows admin action logging as Activée, matching the automated test pass.
`2026-11-04 06:31:12 · SHA-256 1199a67cc82a174d…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Non-compliant → Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Non-compliant → Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Non-compliant → Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)	PSI-4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-04 06:30:58	2c179da7de6b0787cad3ad6fae3d62d345446e556648cce789fc634ec8014804
evidence/C1_after.png	C1 · After fix	2026-11-04 06:31:54	1ac349360cec6caa7ced072fc3ebde76e0411eaa7583e6201378cb68b51f4da4
evidence/C2_before.png	C2 · At testing	2026-11-04 06:30:58	58ab95f59551dd5bce122fa41891fdbcb3fa4fbe05ee556b387565dc1a4b6fc5
evidence/C2_after.png	C2 · After fix	2026-11-04 06:31:52	d9485860f37189c01efeb3ccac134ea6b5d97c0602bfd446b964f96dd21139a1
evidence/C3_before.png	C3 · At testing	2026-11-04 06:30:58	1c48df04737588f1fdd7b8de74b7a6d330585b7306eb38bc0a54c7585ac9ba0d
evidence/C3_after.png	C3 · After fix	2026-11-04 06:31:53	ec30dd44cdc2f97df241d6e6494e726bc471ee7e96a821e9c2923a4019dc4d7b
evidence/C4_before.png	C4 · At testing	2026-11-04 06:30:59	013a9eceeb05ebc41dc91f9e1f7fb05196b9a54977b326825a0609642d5e84c8
evidence/C4_after.png	C4 · After fix	2026-11-04 06:31:51	7d93abc7dc4c2b72482267f3ada82884c82684b7f5a93ffa66e2dad898b29614
evidence/C5_before.png	C5 · At testing	2026-11-04 06:31:14	60a8b9c3793849fd1d1281efccf4a9c91e38ff6aceccb8f6d309376d05e9c73a
evidence/C5_after.png	C5 · After fix	2026-11-04 06:32:08	3ba30f1088538a75d86bb2433ef15a67dec7f8c403f4df39931fed5e140ce60c
evidence/C6_before.png	C6 · At testing	2026-11-04 06:31:12	1199a67cc82a174d96a08abc1d3d251d3bcd044d6b30cd3e658bea57be0ff733

evidence/C7_before.png	C7 · At testing	2026-11-04 06:31:19	189759b0a7634155538ec454f0923726f341c868462178e9500fc16d2d05c94b
evidence/journal.png	System journal		9f3ed18a8888972fb3f29425f99faed1807dc9817e6f84292503fc5de36bfdba

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	18	22,593	23,138	0	0.1266
sam-3.1	12	0	0	12	price not published
Total					**0.1266**

Sensitive data (personal data and secrets) in evidence: 0/8 spotted by Muse Spark + SAM, 8/8 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Human decisions

TICKET	REF.		APPROVED BY	MODE	DATE
CHG-AUD-2026-IAM-01-01	F-01	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 06:31:36
CHG-AUD-2026-IAM-01-02	F-02	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 06:31:36
CHG-AUD-2026-IAM-01-04	F-04	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 06:31:36
CHG-AUD-2026-IAM-01-05	F-05	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 06:31:36
CHG-AUD-2026-IAM-01-06	F-06	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 06:31:36

Safeguards

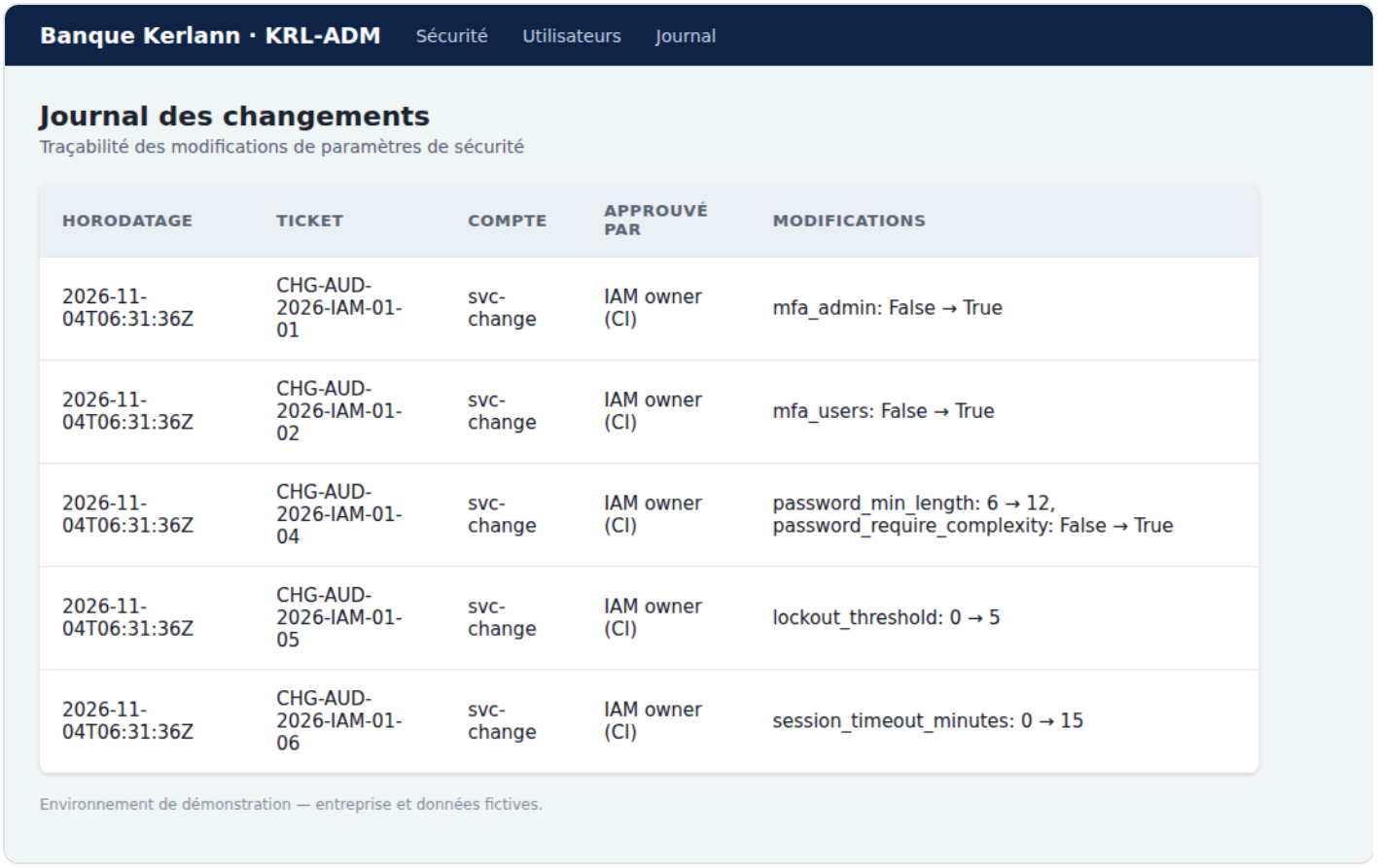
- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

0bc000bed69bac567acb94e02caed68ff60512e62085fc6c69f479b0c0955d69

E. Change log of the audited system



SHA-256 9f3ed18a8888972fb3f29425f99faed1807dc9817e6f84292503fc5de36bfdba